

E-Commerce Payment Gateway - Solution Design v1.0

Confidential - Internal Use Only

Version 1.0

1. Executive Summary

This document outlines the solution design for a secure, PCI-DSS compliant multi-currency payment gateway.

The system will handle credit card, debit card, digital wallet, and bank transfer payments for e-commerce merchants.

Target capacity: 10,000 transactions per minute with 99.99% uptime SLA.

The gateway integrates with Visa, Mastercard, Amex, and PayPal networks.

2. System Architecture

The payment gateway follows a microservices architecture deployed on AWS EKS.

Core services: Payment Processor, Fraud Engine, Tokenization Service, Settlement Engine, Merchant Portal.

All inter-service communication uses gRPC with TLS 1.3 encryption.

Database: PostgreSQL for transactional data, Redis for session caching, Elasticsearch for audit logs.

Message queue: Apache Kafka for async event processing between services.

3. Payment Processing Flow

REQ-ECO-001: The system shall accept payment requests via REST API with JSON payload.

REQ-ECO-002: Card numbers must be tokenized within 50ms of receipt before any storage.

REQ-ECO-003: The authorization request must be forwarded to the acquiring bank within 200ms.

REQ-ECO-004: The system shall support 3D Secure 2.0 for cardholder authentication.

REQ-ECO-005: Failed transactions must be retried up to 3 times with exponential backoff.

REQ-ECO-006: Each transaction must generate a unique reference ID in format

ECO-YYYYMMDD-XXXXXX.

4. Multi-Currency Support

REQ-ECO-007: The system shall support transactions in USD, EUR, GBP, JPY, CAD, AUD, and INR.

REQ-ECO-008: Exchange rates must be fetched from the XE API every 30 minutes.

REQ-ECO-009: Currency conversion must display the exact rate applied before customer confirmation.

REQ-ECO-010: Settlement currency for each merchant is configurable in the merchant profile.

5. Fraud Detection Engine

REQ-ECO-011: The fraud engine shall analyze velocity, geolocation, device fingerprint, and transaction amount.

REQ-ECO-012: Transactions scoring above 85 on the risk scale (0-100) must be auto-declined.

REQ-ECO-013: IP addresses with more than 5 failed attempts in 10 minutes shall be temporarily blocked.

REQ-ECO-014: The system shall maintain a merchant-configurable blacklist of card BINs and countries.

REQ-ECO-015: All fraud decisions must be logged with full audit trail for dispute resolution.

6. Refund and Chargeback Management

REQ-ECO-016: Full and partial refunds must be supported through the merchant dashboard and API.

REQ-ECO-017: Refunds must be processed within 24 hours of initiation.

REQ-ECO-018: The system shall send webhook notifications to merchants for refund status changes.

REQ-ECO-019: Chargeback cases must be trackable with document upload capability.

REQ-ECO-020: Monthly chargeback reports must be auto-generated for each merchant.

7. Security and Compliance

REQ-ECO-021: All cardholder data must be encrypted using AES-256 at rest and TLS 1.3 in transit.

REQ-ECO-022: The system must pass annual PCI DSS Level 1 certification audit.

REQ-ECO-023: Access to production systems requires MFA and is restricted by IP whitelist.

REQ-ECO-024: All API endpoints must implement rate limiting (100 req/sec per merchant).

REQ-ECO-025: Sensitive logs must be masked and retained for 7 years per regulatory requirements.